

Project Proposal

RIS602-NBB-Group 17

Ayaan Hirsi (17317721)

Table of Contents

Introduction / Project Overview.....	3
Project Objectives	4
Proposed Methodology / Plan.....	5
Automated Enumeration Phase	5
Automated Focused Penetration Testing.....	5
Automated Post-Exploitation and Privilege Escalation	5
Automated Lateral Movement and Service Access	6
Automation Framework Implementation.....	6
Tools and Technologies	6
Expected Outcomes	7
Project Limitations/Challenges.....	8
Mitigation Strategies.....	9
Conclusion	10

Introduction / Project Overview

Modern enterprise environments depend on multiple interconnected services, including authenticated systems, web applications, and file-sharing platforms, to support daily business operations. While these services improve efficiency, productivity, and accessibility, they also increase the organization's attack surface and introduce potential security vulnerabilities. If these vulnerabilities are not properly identified and mitigated, they can be exploited by malicious actors. To address these risks, organizations use penetration testing to evaluate their security posture by simulating real-world attack scenarios and identifying weaknesses before they can be exploited.

This project proposes the development of an automated penetration testing demonstration within our SPR500 enterprise network topology. The SPR500 lab environment represents a segmented enterprise infrastructure that includes multiple VLANs, such as user and administrative networks, container-hosted web applications, Active Directory authentication services, and SMB file-sharing systems. The demonstration will simulate an external attacker attempting to gain unauthorized access across these services using automated penetration testing tools and techniques.

The primary goal of this project is to demonstrate how automation can improve the efficiency, reliability, and repeatability of penetration testing processes. Additionally, the project will highlight common security risks within enterprise authentication mechanisms and network segmentation controls, while emphasizing the importance of proactive security testing in protecting organizational infrastructure.

Project Objectives

The primary objectives of this project are to:

- Design and demonstrate an automated penetration testing workflow that integrates key phases such as enumeration, credential testing, post-exploitation, and reporting.
- Simulate realistic enterprise attack paths within the SPR500 multi-VLAN topology to reflect how attackers move through segmented networks.
- Assess the effectiveness of authentication and access controls protecting critical enterprise services across different subnets and VLANs.
- Identify and document security weaknesses within the following in-scope systems and services:
 - Active Directory (authentication and domain-related services)
 - SMB file sharing (share access and permission controls)
 - Internal web applications (IntWeb, CorpWeb, and E-Site authentication and access restrictions)
- Demonstrate impact through controlled compromise, including privilege escalation (where applicable) and lateral movement leading to access of protected resources (e.g., sensitive files)
- Produce clear documentation and actionable recommendations that summarize findings, evidence, and mitigations suitable for an enterprise security context.

Proposed Methodology / Plan

This project will follow a structured and fully automated penetration testing lifecycle designed to simulate a realistic enterprise attack scenario. The methodology demonstrates how an external attacker could systematically identify, exploit, and expand access within the SPR500 enterprise network environment while maintaining a controlled and ethical testing framework. Each stage of the penetration testing process will be automated through scripting and integrated security tools to improve consistency, repeatability, and overall testing efficiency.

Automated Enumeration Phase

The first phase involves automated reconnaissance and enumeration of network services. Scanning tools such as Nmap will be integrated into scripting workflows to continuously identify active hosts, open ports, running services, and authentication mechanisms across multiple VLANs and subnets within the SPR500 environment. The automation will collect and organize scanning results, analyze discovered services, and generate structured output that highlights potential entry points into the network. This automated discovery process enables rapid mapping of the attack surface and assists in identifying systems that may be vulnerable to credential-based or authentication-related attacks.

Automated Focused Penetration Testing

Following the enumeration phase, targeted penetration testing will be conducted through automated credential testing workflows. Scripts will automatically launch authentication attacks against identified services, including user workstations, administrative systems, internal web portals, and SMB file-sharing services. Penetration testing tools will be integrated with controlled wordlists and test accounts to simulate credential-based attacks in a safe testing environment. The automation will dynamically select targets based on enumeration results while recording authentication attempts, successful logins, and failed attempts. This phase demonstrates how automated attack workflows can efficiently identify weaknesses in enterprise authentication controls.

Automated Post-Exploitation and Privilege Escalation

Once initial system access is obtained, automated post-exploitation scripts will evaluate the level of access gained through compromised credentials. The automation will attempt privilege escalation by scanning permission misconfigurations, insecure system policies, and vulnerable

service configurations. Automated privilege validation checks will determine whether compromised user accounts can escalate privileges to administrative levels. This phase highlights the potential security impact of credential compromise and demonstrates how attackers may increase control over enterprise systems through automated exploitation techniques.

Automated Lateral Movement and Service Access

After elevated privileges are obtained, automated lateral movement procedures will be executed to simulate attacker expansion across the network. Scripts will use compromised credentials to attempt access to additional enterprise services, including SMB file-sharing systems and internal web applications. Automated file access testing will attempt retrieval of simulated sensitive files to demonstrate the potential consequences of unauthorized access. The automation will also evaluate whether internal web applications provide authentication pathways or links that enable further service access. This phase demonstrates how attackers can leverage compromised credentials to expand their presence within segmented enterprise networks.

Automation Framework Implementation

Automation will be integrated throughout all penetration testing phases to improve efficiency, accuracy, and repeatability of testing procedures. The automation framework will include:

- Automated network and service enumeration
- Automated credential attack execution
- Automated post-exploitation and privilege escalation testing
- Automated lateral movement and service access validation
- Centralized logging and tracking of successful compromises
- Automated report generation and documentation creation

Automation will be implemented using scripting languages such as Bash or Python integrated with penetration testing tools within a controlled testing workflow. This automated approach demonstrates how enterprise penetration testing processes can be scaled effectively while maintaining reliable and consistent results.

Tools and Technologies

This project will use a combination of industry-standard penetration testing tools and a controlled lab environment in order to simulate realistic enterprise attack workflows in a safe, non-destructive way. The core tools and technologies include:

- SPR500 enterprise lab environment (segmented multi-VLAN topology with representative enterprise services and hosts)

- Kali Linux attacker workstation to run scanning, exploitation support tooling, and automation scripts
- Network discovery and enumeration tooling to identify live hosts, open ports, and exposed services across VLANs
- Credential testing and authentication assessment tools to perform controlled password testing against approved targets and accounts
- Web application testing tools to evaluate internal portals (IntWeb, CorpWeb, E-Site) and validate authentication/access control behavior
- SMB-focused authentication and access testing tools to assess file share exposure, permissions, and credential reuse risk
- Automation scripting (Bash and/or Python) to standardize the workflow, reduce manual repetition, and generate consistent logs and outputs
- Controlled test accounts and scoped wordlists to ensure all authentication testing remains authorized, measurable, and within safe limits.

Expected Outcomes

The expected outcomes of this project include demonstrating a realistic enterprise attack progression within the SPR500 lab topology while highlighting the value of automation in penetration testing. By the end of the project, we expect to demonstrate a complete attack path that begins with initial access on a user-level system, progresses through privilege escalation where applicable, and results in administrative-level access. Using this access, we expect to show how an attacker could reach protected services and retrieve a simulated sensitive file from the SMB file-sharing service.

In addition, the project is expected to identify and document weaknesses in authentication and access controls across key enterprise services, including Active Directory authentication, SMB authentication and share permissions, and internal web application login systems (IntWeb, CorpWeb, and E-Site). We also expect to demonstrate the impact of compromised credentials by showing how access can expand across segmented VLANs and how lateral movement can enable access to additional systems and services. Another outcome will be an evaluation of how effective segmentation rules and access controls are at limiting or preventing unauthorized access within the environment.

Finally, the project is expected to demonstrate improved efficiency and consistency through automation by integrating enumeration, credential testing, logging, and reporting into a structured workflow. The final deliverables will include documented findings, supporting

evidence, and actionable security recommendations aligned with real-world enterprise penetration testing practices.

Project Limitations/Challenges

While this project aims to simulate a realistic enterprise penetration testing scenario, several limitations and challenges may affect its scope and execution.

One key limitation is time constraints, as the project must be completed within an academic timeframe. Due to this, testing depth may need to be limited to selected services rather than conducting a fully exhaustive enterprise assessment.

Another challenge involves limited access permissions and controlled lab policies. Since the project is conducted within the SPR500 lab environment, testing must remain within approved boundaries, using designated test accounts and avoiding any actions that could disrupt shared infrastructure.

The complexity of Active Directory attacks presents an additional technical challenge. Active Directory environments involve domain policies, authentication protocols, permissions and trust relationships that can be complex to enumerate and exploit properly. Automating AD-related attacks while maintaining stability and accuracy requires careful configuration and testing.

There is also a risk of disrupting or misconfiguring the lab environment, particularly when performing credential attacks, privilege escalation attempts, or service enumeration across multiple VLANs. Aggressive testing techniques could potentially lock accounts, trigger defensive controls, or destabilize services.

Tool compatibility and automation integration may present further challenges. Integrating multiple penetration testing tools into a seamless automated workflow can lead to compatibility issues, inconsistent output formats, or scripting errors that require troubleshooting and refinement.

Finally, network segmentation and firewall restrictions within the SPR500 topology may limit direct access between VLANs, requiring additional configuration and testing adjustments to accurately simulate realistic attack paths.

These limitations highlight the importance of careful planning, controlled execution, and incremental testing throughout the project lifecycle.

Mitigation Strategies

To address the project limitations and keep testing safe and reliable, we will use controlled test accounts throughout the engagement so that all authentication attempts remain authorized and do not disrupt unintended users or services. Before beginning any major testing phase, we will take virtual machine snapshots and maintain backups of key systems so that we can quickly roll back the environment if instability or misconfiguration occurs. We will also scope credential-based testing to approved parameters by limiting the number of attempts, using small controlled wordlists, and avoiding aggressive settings that could cause account lockouts or service degradation.

In addition, we will build our automation workflow incrementally by validating each component (such as enumeration, credential testing, logging, and reporting) on a small subset of targets before expanding across the full environment. To prevent scope creep and ensure the project remains achievable, we will focus on the core authentication services and attack paths that align with our objectives, including Active Directory-related authentication, SMB file sharing, and the internal web applications. Throughout testing, we will continuously monitor system stability and service availability by reviewing logs and checking host responsiveness, allowing us to detect issues early and keep all activity contained within the SPR500 lab scope.

Conclusion

This project proposes the development of a fully automated penetration testing demonstration within the SPR500 enterprise network topology. The project is designed to simulate a realistic enterprise attack scenario by automating all major phases of the penetration testing lifecycle, including service enumeration, credential-based exploitation, post-exploitation analysis, privilege escalation, and lateral movement across network services. By focusing on critical enterprise systems such as Active Directory, SMB file-sharing services, and internal web applications, the project demonstrates how attackers can leverage authentication weaknesses to access sensitive organizational resources.

Through the integration of automation across each testing phase, the project highlights how penetration testing activities can be conducted in a more efficient, consistent, and systematic manner. The demonstration also evaluates the effectiveness of network segmentation, authentication controls, and access management mechanisms implemented within the SPR500 environment. Although challenges such as system complexity, automation integration, and limitations within controlled lab environments may arise, these risks will be mitigated through structured testing procedures, responsible use of test credentials, and adherence to ethical penetration testing practices.

Overall, this project aims to provide a realistic representation of enterprise attack progression while emphasizing the importance of strong security controls, proactive vulnerability assessment, and automated testing techniques in identifying and reducing cybersecurity risks. Feedback, suggestions, and recommendations are welcomed to further strengthen the project's scope, methodology, and implementation.